Ce qu'il reste à corriger sur Genius Group

Test exploratoire de **genius-group.vercel.app** : 12 points relevés, aucune faille d'authentification. Chaque ligne se rejoue telle quelle après correction.

03 HAUTE **03** MOYENNE **04** BASSE **02** INFO ORDRE CONSEILLÉ : 1 → 2 → 3 → 5 → 6

01 HAUTE

Deux endpoints appelés par le front n'existent pas côté serveur

`/api/chat` et `/api/evaluations` répondent **404 « Route introuvable »** alors qu'ils sont présents dans le bundle JS. Les écrans qui les utilisent (dont « Assistant IA ») restent vides. → Implémenter côté backend *ou* retirer les appels du front.

TEST Ouvrir « Assistant IA » : la réponse doit s'afficher, plus de 404.

02 HAUTE

Toute URL inconnue affiche une page blanche

Aucune route 404 : ni message, ni redirection, ni retour possible. Un utilisateur qui suit un vieux lien est perdu. → Ajouter une page « Page introuvable » avec un bouton de retour à l'accueil.

TEST Ouvrir `/nimporte-quoi` : message + lien retour visibles.

03 HAUTE

Table des utilisateurs : 68 lignes, sans pagination

Chaque ligne porte 3 boutons ; après quelques interactions la page ne répond plus (clics qui expirent). → Paginer (20 par page) ou virtualiser, avec un indicateur de chargement.

TEST Scroller puis enchaîner 10 clics sans blocage.

04 MOYENNE

« Chargement… » pendant une dizaine de secondes sur la vue globale

Le premier affichage est très long (backend Render en veille). → Écran de chargement explicite et préchauffage du service.

TEST Recharger trois fois : affichage en moins de 3 secondes.

05 MOYENNE

Formulaire incomplet : rien ne se passe, aucun message

Sur « Créer un compte », valider avec les champs vides ne déclenche aucune erreur visible. Idem pour la connexion vide. → Afficher une erreur par champ et mettre le champ fautif en évidence.

TEST Valider à vide : messages visibles, champ ciblé.

06 MOYENNE

Deux identifiants par compte, affichés sans explication

Le panneau de création annonce un **matricule** (26GEN0130) et un **identifiant** (26GEN0114) différents ; la liste n'affiche que le second. Les deux fonctionnent à la connexion, mais l'admin ne sait pas lequel communiquer. → Un seul identifiant affiché, ou libellés explicites.

TEST Créer un compte : le numéro affiché = celui de la liste = celui qui connecte.

07 BASSE

La confirmation de suppression ne nomme pas l'utilisateur

« Supprimer l'utilisateur ? / Le compte sera supprimé définitivement. » — la cible n'apparaît nulle part, pour une action irréversible. → Afficher le nom et le matricule : « Supprimer **QA TEST (26GEN0114)** ? ».

TEST Cliquer Supprimer : le nom apparaît dans la boîte.

08 BASSE

Prénom et Nom ne sont pas obligatoires

Seuls mot de passe, rôle, concours et modalité portent le * — d'où deux comptes admin « David — » en base. → Marquer les champs et bloquer la création sans nom.

TEST Créer sans nom : la création est refusée.

09 BASSE

Les cartes du tableau de bord admin ne sont pas accessibles au clavier

« Créer un compte », « Gérer les comptes », « Espace professeur » n'apparaissent pas dans l'arbre d'accessibilité : ni Tab, ni lecteur d'écran. → Les rendre en <a> ou <button>.

TEST Tab puis Entrée sur « Gérer les comptes » : navigation OK.

10 BASSE

Messages d'erreur API en franglais

« Données invalides : matricule, **password** » alors que l'interface parle de « Mot de passe ». → Harmoniser en français.

TEST Soumettre la connexion vide : message entièrement en français.

11 INFO

Une saisie malformée fait planter la connexion (500)

Le matricule `' OR 1=1 --` renvoie « Erreur serveur » au lieu de 400. **Non exploitable** — les autres charges SQL renvoient bien 401, aucun contournement ni fuite. → Assainir l'entrée et renvoyer 400.

TEST Rejouer la charge : 400 au lieu de 500.

12 INFO

Le contrôle d'accès par rôle reste à vérifier

Un compte élève peut-il appeler les endpoints d'administration ? Non testé, faute d'identifiants élève. C'est le seul test de sécurité restant. → Créer un élève de test, appeler `/api/users/all`, attendre 403.

TEST Élève sur `/api/users/all` : 403 attendu, sinon correctif urgent.

Ce qui va bien, et ce qui reste à couvrir

VÉRIFIÉ ET SOLIDE

401 sur tous les endpoints sensibles sans jeton · limitation des tentatives de connexion (429 après ~6 échecs) · pas d'énumération d'utilisateurs · CORS restreint à l'app · en-têtes CSP, HSTS, X-Frame-Options.

NETTOYAGE

Les 2 comptes de test créés pendant l'audit ont été supprimés : base revenue à 68 utilisateurs, vérifié.

NON TESTÉ

Espaces élève et professeur (quiz, évaluations, notes, ressources, messagerie, planning) · responsive mobile · accès par rôle (point 12) · uploads de fichiers.

PRIORITÉS

1 · 2 · 3 d'abord — ils sont visibles par les utilisateurs. Puis 5 et 6, qui touchent la prise en main et la distribution des accès.

Rapport complet : Rapport_QA_Genius_Group.md — K2/\Labs, audit du 02/11/2026